BTS SIO SISR · THÈME 3 · SÉANCE 1

Corrections

Risques liés aux usages des utilisateurs

Corrigé du QCM

Question	Bonne réponse	Explication
1. Quel est le principal risque de l'incident A ?	Le vol d'identifiants par phishing	Le message menace de suspendre le compte et demande le mot de passe : c'est une tentative de phishing.
2. Quelle mesure est adaptée à l'incident B ?	Alerter le support et appliquer la procédure de révocation des accès	Il faut limiter rapidement l'exposition des données en révoquant les accès liés à l'appareil perdu.
3. Que devait faire le salarié face à la clé USB inconnue ?	La remettre au service compétent sans la connecter	L'origine et le contenu de la clé ne sont pas vérifiés : la connecter expose le poste à une infection.
4. Quelle mesure réduit le risque lié au BYOD ?	Définir des exigences de sécurité et limiter les accès	Une politique écrite, des exigences de sécurité et des accès limités encadrent le risque.
5. Pourquoi une charte informatique est-elle utile ?	Elle définit les règles et comportements attendus	Elle précise les règles d'utilisation et les responsabilités ; elle complète les mesures techniques sans les remplacer.

Méthode attendue à l'examen

D'après le document… → Problème → Risque → Principe de sécurité → Solution → Bénéfice.

Corrigés rédigés de l’étude de cas NovaCom

Incident A — phishing

RÉPONSE MODÈLE (SUPPORT DE COURS)

D’après le document, la comptable reçoit un courriel qui menace de suspendre son compte et lui demande de confirmer son mot de passe. Cette situation présente les caractéristiques d’une tentative de phishing.

Le principal risque est le vol de ses identifiants, qui pourrait permettre à un attaquant d’accéder à la messagerie et aux informations professionnelles. Le principe de sécurité à appliquer est la protection des moyens d’authentification et la vérification de l’origine des demandes.

Il faut éviter de cliquer sur le lien, vérifier la demande par un canal indépendant et signaler le message au support informatique. Cette mesure réduit le risque de compromission du compte et permet à l’entreprise de prendre les mesures de protection nécessaires.

Incident B — BYOD (proposition de corrigé)

PROPOSITION

D’après le document, un commercial perd son smartphone personnel sur lequel sa messagerie professionnelle est connectée. Le problème est la perte d’un appareil personnel donnant accès à des ressources de l’entreprise.

Le risque est un accès non autorisé aux courriels et aux données professionnelles, c’est-à-dire une atteinte à la confidentialité. Le principe de sécurité est la maîtrise des accès, y compris depuis des appareils personnels encadrés par une politique BYOD.

Il faut alerter immédiatement le support, appliquer la procédure de révocation des accès et des sessions, et faire réinitialiser le mot de passe. Cette réaction limite le temps pendant lequel les données restent exposées. À plus long terme, l’entreprise peut imposer le verrouillage de l’appareil, le MFA et, si c’est adapté, une solution de gestion des appareils mobiles.

Incident C — support amovible (proposition de corrigé)

PROPOSITION

D’après le document, un salarié branche une clé USB trouvée dans une salle de réunion. Le problème est l’introduction d’un support dont l’origine et le contenu ne sont pas vérifiés.

Le risque est l’infection du poste par un fichier malveillant, avec une possible propagation au réseau et une atteinte à la confidentialité, à l’intégrité ou à la disponibilité. Le principe de sécurité est de n’utiliser que des supports autorisés et vérifiés.

Il fallait remettre la clé au service compétent sans la connecter. Si elle a déjà été branchée, le salarié doit prévenir le support sans attendre et suivre ses instructions, sans tenter de réparer le poste seul. Cette mesure évite l’introduction d’un code malveillant dans le système d’information.

Analyse des écarts — charte ABC Services

Règle ou situation	Problème identifié	Recommandation
BYOD autorisé sans conditions précisées	Risque de fuite de données ou d'accès non autorisé	Définir les conditions de sécurité du BYOD.
Clés USB personnelles sans contrôle	Introduction possible de fichiers malveillants et fuite de données	Limiter les supports autorisés et prévoir des contrôles adaptés.
Connexion distante sans dispositif précisé	Accès potentiellement insuffisamment protégé	Définir une procédure d'accès distant sécurisé, avec authentification forte.
Signalement des messages suspects	Bonne pratique déjà présente	Maintenir la règle et sensibiliser les utilisateurs.

Attention : l'absence d'une règle dans un extrait ne prouve pas forcément que toute l'entreprise est dépourvue de mesures de sécurité. Il faut rester dans le périmètre du document analysé.